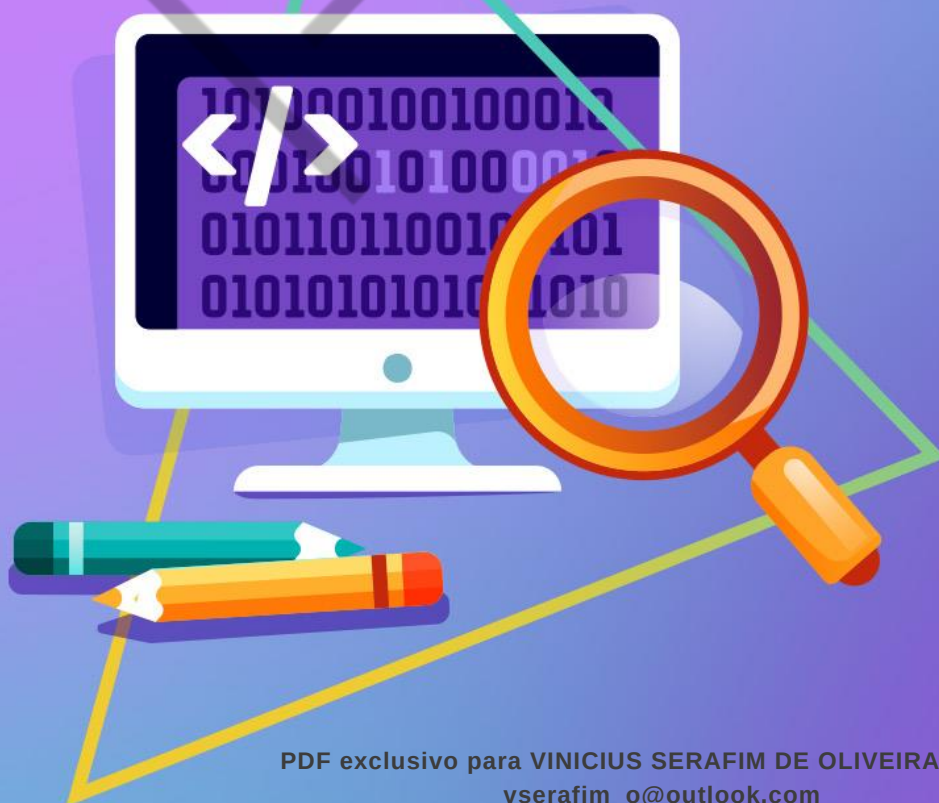


PYTHON O CÓDIGO DA
RESISTÊNCIA CONTRA O IMPÉRIO

GESTÃO DE VULNERABILIDADES



10

LISTA DE FIGURAS

Figura 1 – Site Common Vulnerabilities and Exposures (CVE).....	7
Figura 2 – Calculadora Common Vulnerability Scoring System Version 3.0	9
Figura 3 – Dados da empresa Equifax	12
Figura 4 – Resultados de pesquisa por vulnerabilidade em sistemas.....	13
Figura 5 – CVEs publicadas por ano	16
Figura 6 – Ciclo de vida da gestão de vulnerabilidades	20

EMANIP

LISTA DE QUADROS

Quadro 1 – Níveis de severidade e os intervalos base de pontuação de acordo com o CVSS9



SUMÁRIO

1 INTRODUÇÃO	5
2 QUEM ESTÁ VULNERÁVEL?.....	5
3 O TAMANHO DA ORGANIZAÇÃO INFLUENCIA EM ALGO?.....	6
3.1 Quem está em risco?	6
4 MÉTRICAS DE VULNERABILIDADES	8
4.1 Classificações de gravidade da vulnerabilidade do NVD	8
5 VULNERABILIDADES PROVÊM DE ERROS DE PROGRAMAÇÃO	10
5.1 De onde vêm as vulnerabilidades?	10
6 UM POUCO MAIS SOBRE O QUE CAUSA VULNERABILIDADES	11
7 TENDÊNCIAS EM ATAQUES CIBERNÉTICOS	12
8 GESTÃO DE VULNERABILIDADES	14
9 ELEMENTOS PARA UMA GESTÃO DE VULNERABILIDADES	15
9.1 Escopo da vulnerabilidade	16
9.2 Verificação de vulnerabilidade.....	17
10 GESTÃO DE VULNERABILIDADE NA PRÁTICA.....	18
11 CICLO DE VIDA DA GESTÃO DE VULNERABILIDADES.....	19
12 QUAL É O PROCESSO DA GESTÃO DE VULNERABILIDADES?.....	20
13 COMO MELHORAR A ESTRATÉGIA DA GESTÃO DE VULNERABILIDADES..	21
14 AVALIAÇÃO DE VULNERABILIDADE E TESTE DE PENETRAÇÃO	22
REFERÊNCIAS.....	25

1 INTRODUÇÃO

Na área de segurança cibernética, uma vulnerabilidade é uma fraqueza que pode ser explorada por um ataque cibernético a fim de obter acesso não autorizado ou executar ações também não autorizadas em um sistema de computador.

O ***Technical Guide to Information Security Testing and Assessment (NIST)*** define vulnerabilidade como uma fraqueza em um sistema de informações, procedimentos de segurança do sistema, controles internos ou de implementação que podem ser explorados ou acionados por uma fonte de ameaça. Na ISO 27005, a definição está relacionada a uma fragilidade de um ativo ou grupo de ativos que pode ser explorada por uma ou mais ameaças.

De forma geral, os sistemas de computadores em princípio são vulneráveis, visto o modo como são elaborados, pois podem apresentar falhas no design, na implementação ou em sua operação, e o gerenciamento desses sistemas pode ser explorado para violar a política de segurança.

As vulnerabilidades podem permitir que os invasores executem códigos, acessem a memória de um sistema, instalem *malwares* (software malicioso) e roubem, destruam ou modifiquem dados confidenciais.

Para explorar uma vulnerabilidade, um invasor deverá conectar-se ao sistema do computador e então utilizar, entre as diversas técnicas ou ferramentas disponíveis, um método para explorar as vulnerabilidades existentes. Por exemplo, entre essas variedades de métodos, estão disponíveis *SQL injection*, *buffer overflows*, *cross-site scripting* (XSS) e kits de exploração de código aberto que procuram vulnerabilidades conhecidas e pontos fracos de segurança em aplicativos da web.

A existência de um erro, design ou implementação pode levar a um evento indesejável inesperado que talvez comprometa a segurança ambiente, seja o sistema, a rede ou as aplicações envolvidas.

2 QUEM ESTÁ VULNERÁVEL?

Para que você possa responder a essa pergunta, é preciso compreender a necessidade da gestão de vulnerabilidades em um ambiente tecnológico.

Para um cibercriminoso, as vulnerabilidades existentes nos sistemas podem ser direcionadas à exploração, o que resulta em acesso não autorizado à rede e aos ativos de alto valor. Uma vez que o invasor obtém acesso ao ambiente, a intenção pode ser procurar informações pessoais, dados de cartão de crédito, contas bancárias, além de segredos comerciais e propriedade intelectual, de forma geral, a busca será por algo que possa negociar. Além disso, o computador explorado agora é uma porta de entrada para novos ataques à sua rede e se tornará parte de uma plataforma que poderá ser utilizada para atacar a rede de outras organizações.

Pesquisadores de segurança da informação estão continuamente descobrindo falhas em softwares, configurações defeituosas de aplicativos e equipamentos de TI. Vale lembrar que os softwares são desenvolvidos por humanos e, muitas vezes, não são testados exaustivamente em busca de falhas, consequentemente novas vulnerabilidades aparecem todos os dias.

Qualquer que seja sua fonte, as vulnerabilidades não desaparecem sozinhas, você deve pressupor que detecção, remoção e controle requerem gerenciamento de vulnerabilidades e o uso contínuo de ferramentas de segurança especializadas, juntamente com um fluxo de trabalho que incentive identificar e eliminar potenciais riscos ou eventos que prejudiquem a segurança da informação.

3 O TAMANHO DA ORGANIZAÇÃO INFLUENCIA EM ALGO?

3.1 Quem está em risco?

Todos os sistemas com conexão à internet, disponíveis tanto nas organizações como em casa, estão em risco devido às possíveis vulnerabilidades existentes. Você pode perguntar: O tamanho da organização influencia em algo? A resposta geralmente é que, para uma empresa nacional, multinacional ou um governo, não faz diferença, você sempre estará em risco.

O principal desafio das empresas é manter seguro o acesso a algumas informações, tanto para clientes como para fornecedores e parceiros de negócios em todo o mundo.

Mas, infelizmente, tornar essas informações altamente disponíveis e com acesso seguro é um trabalho muito árduo, visto que uma grande quantidade de

malwares, como vírus, representa uma ameaça constante de roubo de informações e interrupção das operações comerciais.

A taxa crescente de novas vulnerabilidades descobertas a cada dia e a velocidade com que novos modos de explorar essas vulnerabilidades são criados tornam esse desafio ainda mais acentuado. Quando os sistemas de computadores funcionam sem atualizações de segurança recentes, eles tornam-se os alvos preferidos de uma grande variedade de ameaças e de indivíduos em busca de vulnerabilidades.

Você pode visitar o site <http://cve.mitre.org/index.html> e observar algumas das mais conhecidas vulnerabilidades de segurança cibernética. O **Common Vulnerabilities and Exposures (CVE)** permite a realização de pesquisas, com o objetivo de proporcionar o conhecimento de fragilidades em sistemas operacionais e aplicações. Cada uma dessas vulnerabilidades tem um número de identificação, uma descrição e pelo menos uma referência pública. As entradas do CVE são usadas em produtos e serviços de segurança cibernética de todo o mundo.

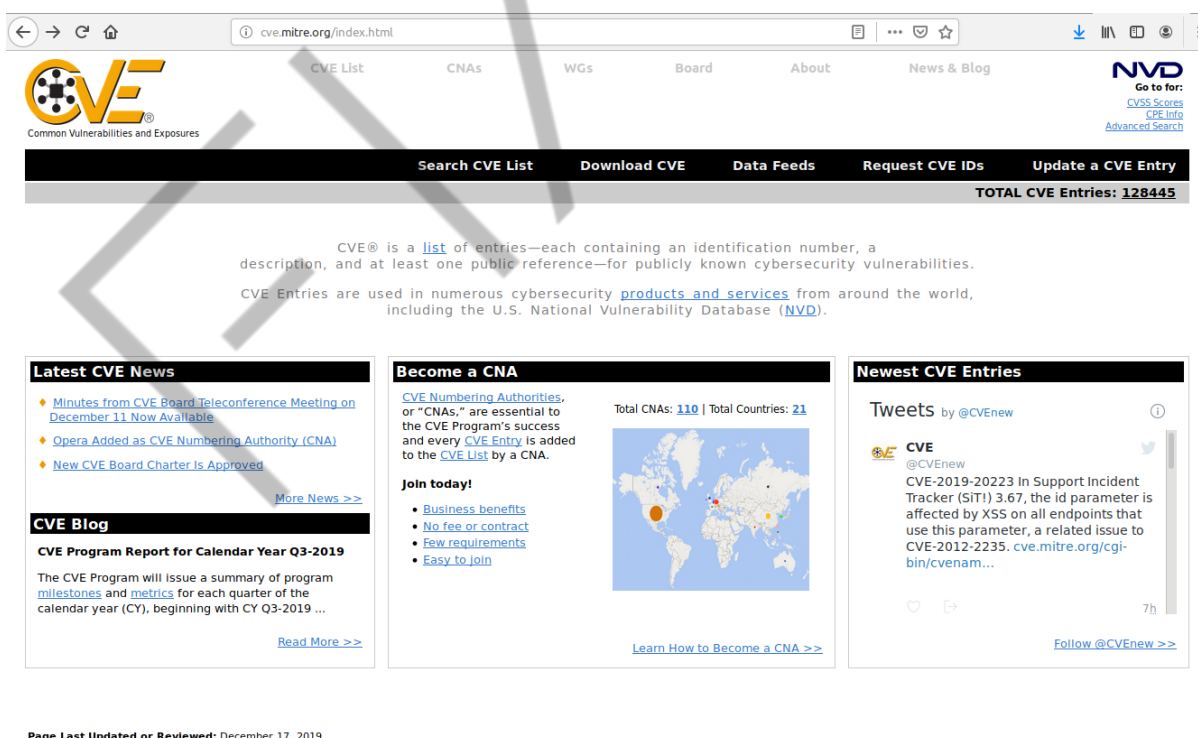


Figura 1 – Site Common Vulnerabilities and Exposures (CVE)
Fonte: Elaborada pelo autor (2020)

Mais adiante, você obterá mais detalhes sobre como lidar com esses identificadores.

4 MÉTRICAS DE VULNERABILIDADES

O **Common Vulnerability Scoring System (CVSS)** é um *framework* para a divulgação das características e da gravidade das vulnerabilidades relacionadas a softwares. O CVSS consiste em três grupos de métricas: base, temporal e ambiental. As métricas de base produzem uma pontuação que varia de 0 a 10 e podem ser modificadas com a pontuação das métricas temporal e ambiental.

Uma pontuação CVSS é bem adequada como um sistema de medição padrão para indústrias, organizações e governos que precisam de pontuações de severidade de vulnerabilidades precisas e consistentes.

O **National Vulnerability Database (NVD)** fornece pontuações CVSS para quase todas as vulnerabilidades conhecidas e afirma que tais pontuações são usadas (NVD, 2020):

1. Para calcular a gravidade das vulnerabilidades descobertas nos sistemas.
2. Como um fator na priorização das atividades de correção de vulnerabilidades.

O NVD disponibiliza uma calculadora CVSS, nas versões 2 e 3, para permitir que você adicione dados de pontuação temporal e ambiental. O CVSS pertence à FIRST.Org, Inc., e também é gerenciado por essa organização sem fins lucrativos sediada nos EUA, cuja missão é ajudar as equipes de resposta a incidentes de segurança de computadores em todo o mundo.

4.1 Classificações de gravidade da vulnerabilidade do NVD

O NVD fornece classificações qualitativas de gravidade/severidade que vão de “baixa” e “média” para “alta”, em relação aos intervalos de pontuação base do CVSS v3.0, além das classificações de gravidade do CVSS v3.0, conforme definidas na especificação dessa versão.

Observe que o Quadro “Níveis de severidade e os intervalos base de pontuação de acordo com o CVSS” apresenta os níveis de gravidade/severidade e os intervalos base de pontuação, de acordo com a classificação das versões 2.0 e 3.0.

Classificação CVSS v2.0		Classificação CVSS v3.0	
Severidade	Intervalo de pontuação	Severidade	Intervalo de pontuação
		Nenhum	0.0
Baixa	0.0-3.9	Baixa	0.1-3.9
Média	4.0-6.9	Média	4.0-6.9
Alta	7.0-10.0	Alta	7.0-8.9
		Crítica	9.0-10.0

Quadro 1 – Níveis de severidade e os intervalos base de pontuação de acordo com o CVSS

Fonte: Elaborado pelo autor (2020)

Você pode conhecer melhor o CVSS acessando o site <<https://www.first.org/cvss/>>, além disso, pode conhecer mais detalhes sobre a calculadora do CVSS 3.0 nesse mesmo site, por meio do seguinte link <<https://www.first.org/cvss/calculator/3.0>> (Figura “Calculadora Common Vulnerability Scoring System Version 3.0”):

The screenshot displays the 'Common Vulnerability Scoring System Version 3.0 Calculator' interface. The main content area is titled 'Base Score' and contains several sections for selecting vulnerability metrics. Each section has a set of buttons for different values. A sidebar on the left provides navigation links, and a top navigation bar includes links for 'About', 'Membership', 'Initiatives', 'Standards & Publications', 'Events', 'Education', and 'Blog'. A 'Sign In' button is also present in the top right corner.

Base Score

Attack Vector (AV)

Network (N) Adjacent (A) Local (L) Physical (P)

Attack Complexity (AC)

Low (L) High (H)

Privileges Required (PR)

None (N) Low (L) High (H)

User Interaction (UI)

None (N) Required (R)

Scope (S)

Unchanged (U) Changed (C)

Confidentiality (C)

None (N) Low (L) High (H)

Integrity (I)

None (N) Low (L) High (H)

Availability (A)

None (N) Low (L) High (H)

Select values for all base metrics to generate score

Figura 2 – Calculadora Common Vulnerability Scoring System Version 3.0

Fonte: Elaborada pelo autor (2020)

5 VULNERABILIDADES PROVÊM DE ERROS DE PROGRAMAÇÃO

5.1 De onde vêm as vulnerabilidades?

Erros de programação (os famosos *bugs*) geram a maioria das vulnerabilidades nos softwares. Um erro que acontece na área de gerenciamento de memória de programas é deixar os blocos de dados usados, mesmo depois de serem declarados livres por outras partes dos programas. Quando esse erro de programação é encontrado pelos invasores, estes geralmente o exploram para obter controle sobre o computador.

Os cientistas da computação estimam que a cada mil linhas de código em produtos de software bem gerenciados contenham cerca de um *bug*. Um sistema operacional como o Windows 7, por exemplo, possui 40 milhões de linhas de código, um aplicativo do Microsoft Office tem entre 30 e 50 milhões, enquanto navegadores populares da internet possuem entre 5 e 10 milhões (KANDEK, 2015). É por isso que você constantemente recebe anúncios de novas atualizações com correções e soluções alternativas relacionadas às vulnerabilidades.

Os invasores não desenvolvem explorações para todas as vulnerabilidades que são publicadas, mas examinam de maneira constante vulnerabilidades críticas em pacotes de software amplamente instalados. Para você ter uma ideia do alcance dos invasores, considere que algumas empresas que desenvolvem software determinam que até 25% das vulnerabilidades publicadas são exploradas nos primeiros 30 dias após a publicação (KANDEK, 2015).

As fraquezas dos sistemas provêm de erros de programação, uma vez que os aplicativos contêm vulnerabilidades expostas por configurações incorretas. Imagine, por exemplo, uma configuração inadequada de aplicativos de segurança, por exemplo, um *firewall*, permitindo aos invasores passarem pelas normas de segurança e acessarem as informações em uma rede. Se é que tais normas foram configuradas corretamente.

A melhor maneira de combater essas ameaças é identificar e eliminar rapidamente todas as vulnerabilidades, e você deve realizar esse procedimento de

forma contínua. A exploração de vulnerabilidades via internet é um enorme problema e requer controle e gerenciamento proativo imediato.

É por isso que as empresas precisam implementar a gestão de vulnerabilidades para detectar e eliminar proativamente as vulnerabilidades, a fim de reduzir o risco geral à segurança e impedir a exposição de dados e informações.

6 UM POUCO MAIS SOBRE O QUE CAUSA VULNERABILIDADES

Além das causas apontadas anteriormente, existem muitas outras origens de vulnerabilidades, incluindo:

- **Complexidade:** sistemas complexos aumentam a probabilidade de uma falha, configuração incorreta ou acesso não intencional.
- **Familiaridade:** código, software, sistemas operacionais e hardware comuns aumentam a probabilidade de um invasor encontrar ou obter informações sobre vulnerabilidades conhecidas.
- **Conectividade:** quanto mais conectado um dispositivo, maior o tempo e a chance de explorar uma vulnerabilidade.
- **Gerenciamento inadequado de senhas:** senhas fracas podem ser quebradas com força bruta, e a reutilização de senhas pode resultar em muitas violações de dados.
- **Falhas no sistema operacional:** como qualquer software, os sistemas operacionais podem conter falhas.
- **Entrada não verificada do usuário:** se o seu site ou software assumir que todas as entradas são seguras, ele poderá executar comandos SQL não intencionais.
- **Pessoas:** a engenharia social é um das maiores ameaças para a maioria das organizações, assim como a falta de conhecimento e de treinamento em segurança da informação.

7 TENDÊNCIAS EM ATAQUES CIBERNÉTICOS

As divulgações constantes de violação de dados nas notícias documentaram a exposição não autorizada de milhões de registros confidenciais de consumidores em todo o mundo. O dano resultante à reputação de uma organização violada pode ser significativo, fazendo com que os clientes levem seus negócios para outro lugar.

Vale lembrar do ataque à empresa Equifax, em que a empresa multinacional de crédito confirmou que um ataque cibernético resultou em acesso ilimitado aos dados de 143 milhões de consumidores estadunidenses (nomes, número de previdência social e carteira de motorista). Horas após a divulgação, houve queda de 12,38% no valor das ações da empresa.

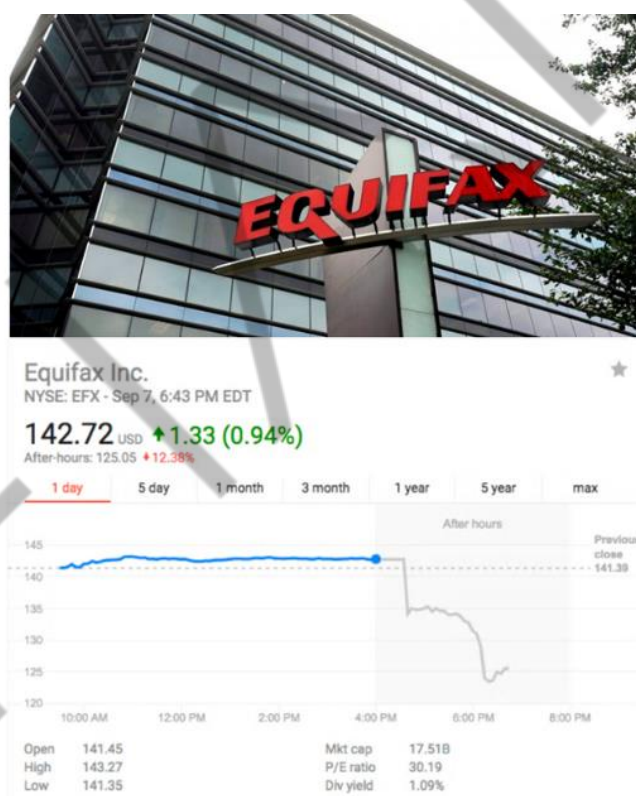


Figura 3 – Dados da empresa Equifax
Fonte: Elaborada pelo autor (2020)

A consequência desse dano é uma prova adequada do motivo pelo qual as organizações devem fazer mais para proteger seus sistemas e redes contra os ataques cibernéticos. A Figura “Resultados de pesquisa por vulnerabilidade em sistemas” apresenta os resultados de uma pesquisa feita na internet sobre notícias

relacionadas às “vulnerabilidades em sistemas”. Se você parar por um instante para ler essas matérias e também fizer a mesma pesquisa, provavelmente observará que as ocorrências são inúmeras.

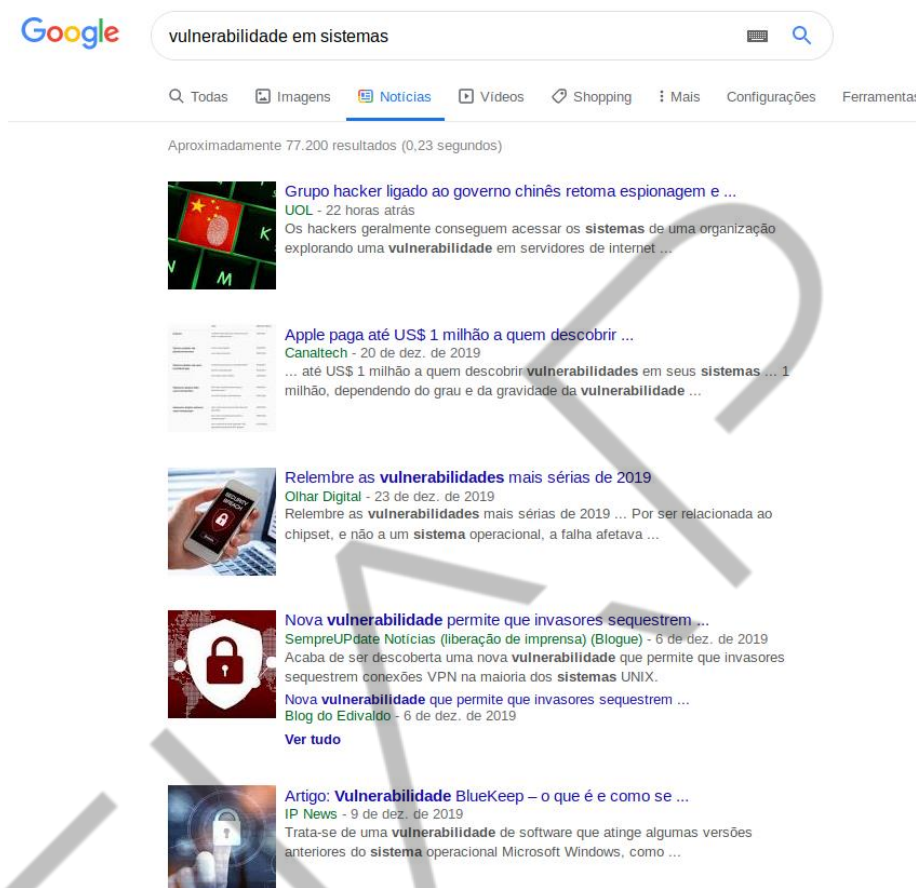


Figura 4 – Resultados de pesquisa por vulnerabilidade em sistemas
Fonte: Elaborada pelo autor (2020)

Em uma estratégia de segurança cibernética, os *endpoints* (*laptops* e estações de trabalho) são considerados “elos mais fracos”, já que atualmente 80% dos ataques cibernéticos acontecem em tais equipamentos.

Jim Souders, chefe executivo da Adaptiva, considera que o cibercrime deve custar US\$ 6 trilhões anuais até 2021 (SOUDERS, 2019) e que garantir a segurança nos *endpoints* é uma prioridade absoluta. Por esse motivo, você deve prestar mais atenção na rápida evolução do gerenciamento de vulnerabilidades. As empresas modernas entendem que precisam impulsionar a conformidade para reduzir os riscos e precisam fazer isso de uma maneira decididamente mais eficiente.

8 GESTÃO DE VULNERABILIDADES

Em um cenário tradicional em que a gestão de vulnerabilidades está presente, a equipe de Segurança da Informação (SI) deve encontrar o maior número possível de vulnerabilidades e corrigi-las, ou indicar a solução para a equipe de Tecnologia da Informação (TI). Esse é um processo muito trabalhoso, em que as respectivas equipes pesquisam vulnerabilidades, aplicam *patches*, realizam testes de penetração e avaliações de vulnerabilidades, entre muitas outras coisas. Embora o processo de gestão de vulnerabilidades seja impossível sem a assistência de software, os modelos tradicionais ainda dependem muito da inteligência humana para tomar uma ampla gama de decisões e definir ações.

A equipe de TI deve determinar quais alterações, se houver alguma, precisam ser realizadas e necessita executar atividades de conformidade de rotina, que demandam um tempo significativo. Infelizmente, você deve saber que tempo disponível é algo que as empresas simplesmente não têm. Algumas empresas contam com equipes de TI muito reduzidas, devido ao orçamento e às restrições de recursos disponíveis e, diante desse cenário, a gestão de vulnerabilidades pode sofrer em razão da falta de profissionais capacitados.

À medida que a tecnologia avança, torna-se essencial a capacidade de automatizar cada vez mais componentes do processo de gestão de vulnerabilidades. E um dos aspectos mais subestimados da gestão moderna de vulnerabilidades é a flexibilidade que pode acompanhar as soluções automatizadas.

Embora alguns produtos ou ferramentas apresentem opções pré-configuradas para ajudar as equipes de TI em alguns dos processos onerosos durante o desenvolvimento de verificações ou ações de correção de vulnerabilidades, a próxima geração de ferramentas dará um passo adiante.

Além de automatizar uma grande porcentagem dos processos de gestão de vulnerabilidades, as equipes terão a opção de criar verificações personalizadas de integridade, conformidade e segurança, além de ações de correção automatizada.

Mais adiante, você aprenderá mais sobre ferramentas relacionadas ao processo de gestão de vulnerabilidades.

9 ELEMENTOS PARA UMA GESTÃO DE VULNERABILIDADES

No início, as ameaças eram apenas os *hackers*, em razão do método que utilizavam para acessar a rede por meio de portas abertas no *firewall* ou explorar vulnerabilidades conhecidas em sistemas acessíveis pela internet, como servidores da web e de e-mail. Dessa forma, você basicamente protegia sua rede implementando regras em um *firewall* e, é claro, precisava testá-lo periodicamente.

O cenário de ameaças atual oferece aos invasores uma seleção muito maior de pontos de ataque na forma de portas de firewall abertas para o tráfego comercial, servidores da web ou outros servidores atrás do firewall, além de todos os aplicativos em execução internamente na rede, incluindo os *endpoints* e os servidores. Isso oferece aos cibercriminosos diversos métodos para encontrar vulnerabilidades em sua rede.

Os invasores ainda têm aplicativos que eliminam qualquer dificuldade de invadir sua rede e tais aplicativos podem ser usados para executar ataques automatizados de alta velocidade que eram impensáveis há alguns anos. Computadores comprometidos em todo o mundo podem ser agrupados logicamente nos chamados *botnets* e, com o uso de *software* de comando e controle, podem realizar ataques coordenados contra os maiores e mais sofisticados sistemas.

Ataques direcionados a sistemas internos são mais lucrativos financeiramente e mais eficazes que ataques externos. SPAM, *phishing*, engenharia social, *malware*, cavalos de Troia, dispositivos de mídia portáteis e outros métodos são comumente usados para comprometer sistemas, subvertendo completamente as soluções de segurança tradicionais, como *firewalls*, sistemas de detecção de intrusão e até verificações de vulnerabilidades externas.

Um aspecto positivo é que muitos desses métodos de ataque dependem de alguma vulnerabilidade do sistema e muitos ataques procuram pontos fracos ou configurações incorretas no navegador e nas aplicações web. Identificar e corrigir essas vulnerabilidades se torna um dos desafios que você pode enfrentar para ficar à frente dos cibercriminosos.

9.1 Escopo da vulnerabilidade

Você precisa, antes de tudo, entender o escopo do problema de vulnerabilidade e, para isso, é preciso ter ciência de que existem tipos diferentes de vulnerabilidades conhecidas. Por esse motivo, é necessário se concentrar nas diferentes variedades e saber que existem muitas outras para se descobrir. Na elaboração desse conteúdo, constatamos que existem mais de 130 mil vulnerabilidades e, para constatar essa informação, você pode consultar o site do CVE para saber a quantidade de vulnerabilidades descobertas até o momento. A Figura “CVEs publicadas por ano” exibe a quantidade de vulnerabilidades publicadas desde o início dos registros, em 1999.



Figura 5 – CVEs publicadas por ano
Fonte: Elaborada pelo autor (2020)

Há, realmente, um número crescente de vulnerabilidades registradas e é isso que as pessoas chamam de vulnerabilidades conhecidas, mas devemos levar em conta que existem também as vulnerabilidades desconhecidas. Depois que uma vulnerabilidade é encontrada, os *scripts* de vulnerabilidade podem ser escritos para procurá-las e identificá-las.

Nem todas essas vulnerabilidades afetam todos os sistemas diariamente, mas com o passar do tempo é provável que muitas vulnerabilidades sejam identificadas

em cada um dos seus sistemas. As questões com as quais você deve se preocupar e das quais deve estar ciente incluem o seguinte:

- **Sob o radar:** às vezes, os criminosos descobrem vulnerabilidades em uma rede, um sistema ou um aplicativo e fazem uso delas para comprometer sua rede. Essas vulnerabilidades são difíceis de detectar, uma vez que os sistemas são projetados para detectar ataques conhecidos, um serviço que realize a detecção de intrusão não terá assinaturas para procurar e identificar esses ataques em suas redes.
- **0-Day Exploration:** outras vezes, alguém anunciará ou liberará informações sobre uma vulnerabilidade para a qual não há uma correção ou um *patch* que neutralize essa fraqueza. Esse tipo de vulnerabilidade é conhecido como vulnerabilidade de dia zero. Os criminosos podem explorar a vulnerabilidade antes que *patches* e correções estejam disponíveis. Geralmente, há maneiras de impedir o ataque, se conhecido, antes do lançamento do *patch*, no entanto é difícil acompanhar o grande volume de vulnerabilidades existentes.

De acordo com o volume de vulnerabilidades existentes, algumas das etapas a seguir são necessárias para proteger a sua organização.

9.2 Verificação de vulnerabilidade

Uma verificação de vulnerabilidade é o processo usado em sistemas operacionais, serviços e aplicativos para identificar a existência de fragilidades que possam ser exploradas.

Esse processo é realizado principalmente com ferramentas que mantêm um banco de dados de *scripts*, os quais podem ser utilizados para detectar vulnerabilidades conhecidas nos sistemas.

O resultado é um relatório que enumera quais sistemas são vulneráveis, de que maneira eles são vulneráveis e a criticidade da vulnerabilidade encontrada.

Esses documentos são conhecidos como relatórios de avaliação de vulnerabilidades. As verificações executadas em dispositivos acessíveis pela internet são conhecidas como avaliações de vulnerabilidades externas, enquanto as

verificações executadas em sistemas na parte interna da rede são conhecidas como avaliações de vulnerabilidades internas.

As **avaliações de vulnerabilidades externas** sempre foram consideradas as mais críticas, porque os dispositivos acessíveis pela internet, como *firewalls*, servidores web, servidores de e-mail, entre outros, estão mais expostos a invasores. Esses sistemas normalmente expõem as portas e os serviços nos quais a maioria das vulnerabilidades podem ser descobertas, como a porta 80, onde os sites estão hospedados. É claro que existem inúmeras outras portas e serviços que possuem vulnerabilidades conhecidas, muitas das quais expostas via Internet.

Os invasores também desenvolveram métodos para comprometer as vulnerabilidades existentes nos sistemas localizados na rede interna, esses ataques geralmente são uma combinação entre um tipo de engenharia social e um *malware*. Os processos relacionados devem fazer parte das avaliações de vulnerabilidades internas.

10 GESTÃO DE VULNERABILIDADE NA PRÁTICA

A gestão de vulnerabilidades está relacionada diretamente com identificar, mitigar e reparar vulnerabilidades em sistemas e redes. As organizações usam a gestão de vulnerabilidades como um processo proativo para melhorar a segurança em aplicativos, software e redes de computadores. Quando bem implementada, a gestão de vulnerabilidades pode ajudar uma organização a tornar-se significativamente mais segura contra violações de segurança e roubo de dados.

Da mesma forma, o gerenciamento de *patches* é a implantação de um *patch* de computação para reparar uma vulnerabilidade em um sistema. Um *patch* é um conjunto de alterações realizadas em um programa projetado para atualizar, corrigir ou melhorar sua funcionalidade. O manuseio adequado desse processo é crucial, pois mais de 80% das violações de segurança são resultado de um gerenciamento inadequado de *patches* (SMITH, 2017).

Antes de abordar as especificidades da gestão de vulnerabilidades e das práticas recomendadas, é importante entender as diferenças entre vulnerabilidades e riscos à segurança, pois os termos geralmente são conflitantes. Um risco em segurança da informação descreve o potencial de perda, dano ou destruição de um

ativo. Uma vulnerabilidade descreve uma fraqueza específica que um invasor pode explorar para executar ações não autorizadas em um sistema de computador. Embora os riscos levem em consideração as vulnerabilidades e as avaliem juntamente com ameaças e ativos, elas não são a mesma coisa. Você deve compreender essa diferença, pois é o primeiro passo para melhorar as práticas de segurança.

11 CICLO DE VIDA DA GESTÃO DE VULNERABILIDADES

O ciclo de vida da gestão de vulnerabilidades descreve as etapas específicas que precisam ser tratadas continuamente no processo da gestão de vulnerabilidades. As especificidades variam de organização para organização, mas existem vários elementos que serão relevantes e úteis para a maioria delas:

- **Descobrir:** saiba onde estão os pontos fracos da rede.
- **Priorizar:** categorize ativos em grupos e atribua um valor com base em quão críticos eles são para as operações do seu ambiente computacional.
- **Avaliar:** avalie a disposição e a capacidade do seu ambiente em assumir riscos com base na criticidade de ativos e nas ameaças em potencial.
- **Relatório:** avalie o nível de risco associado aos ativos do seu ambiente de acordo com as políticas de segurança de suas organizações.
- **Corrigir:** priorize e corrija vulnerabilidades de acordo com o risco atribuído.
- **Verificar:** verifique se as ameaças foram eliminadas.

Se você abordar todas essas etapas em seu processo de gestão de vulnerabilidades, terá melhores chances de manter os sistemas e as redes protegidos.

12 QUAL É O PROCESSO DA GESTÃO DE VULNERABILIDADES?

O processo da gestão de vulnerabilidades leva em consideração o ciclo de vida de gerenciamento, como mostrado na Figura “Ciclo de vida da gestão de vulnerabilidades” e mencionado acima, e pode ser utilizado como um guia de ação. Aqui são apresentados alguns processos principais que você pode implementar para melhorar a segurança de vulnerabilidades e manter seus sistemas e redes protegidos:

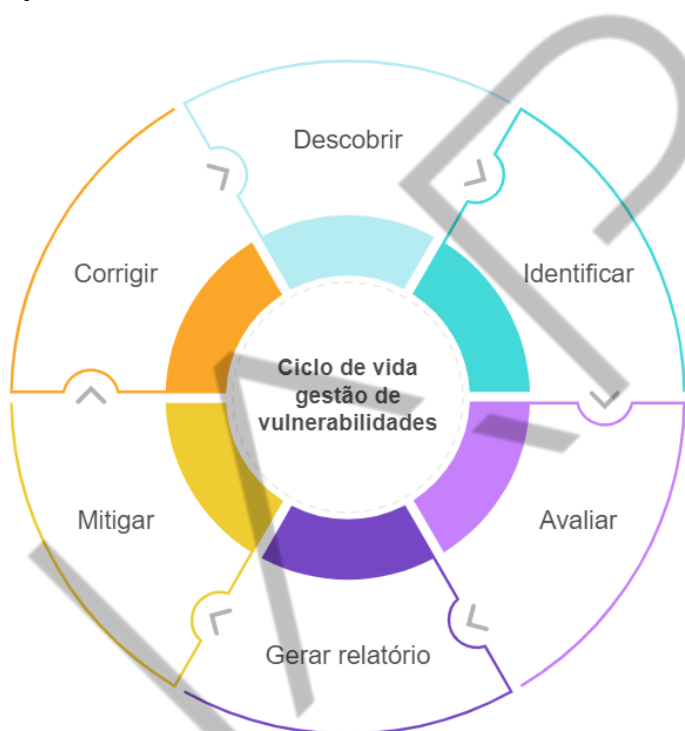


Figura 6 – Ciclo de vida da gestão de vulnerabilidades
Fonte: Elaborada pelo autor (2020)

1. Descobrir vulnerabilidades: verificações de rede, logs de *firewall* e testes de penetração são ferramentas importantes da gestão de vulnerabilidades para localizar quaisquer pontos fracos que as redes e os sistemas do seu ambiente possam ter. Você deve usar essas ferramentas regularmente e, se possível, automatizá-las.

2. Identificar as vulnerabilidades: usando os dados gerados nos logs, testes e varreduras, você pode localizar qualquer anomalia que indique uma má ação nas redes e nos sistemas do seu ambiente (ataques de *malware*, atividades suspeitas etc.).

3. Avaliar as vulnerabilidades: determine se as vulnerabilidades identificadas têm o potencial de serem exploradas em servidores, aplicativos, redes ou outros sistemas.

4. Gerar relatório (reportar): avalie o nível de risco associado aos ativos do seu ambiente computacional de acordo com as políticas de segurança de suas organizações.

5. Mitigar as vulnerabilidades: se um *patch* não puder ser emitido rapidamente ou se não houver uma solução de *patch* para uma determinada vulnerabilidade, você precisará criar soluções de espaço reservado para o ambiente onde se encontram seus ativos. Você pode considerar colocar off-line a parte afetada de um sistema ou colocar um ataque em quarentena.

6. Corrigir as vulnerabilidades: depois de identificar uma vulnerabilidade e avaliar que ela representa um risco, é hora de corrigir. Geralmente, os *patches* podem ser obtidos ou adquiridos dos fornecedores do software ou hardware afetado. Se possível, tente agendar um horário para a instalação do *patch*, de modo a não interferir na atividade do usuário.

13 COMO MELHORAR A ESTRATÉGIA DA GESTÃO DE VULNERABILIDADES

Todas as ações propostas pelos processos da gestão de vulnerabilidades abordam as preocupações e as etapas definidas pelo modelo de ciclo de vida, mas elas não são as únicas ações que os profissionais de segurança da informação podem executar para melhorar seus serviços. Veja, a seguir, algumas práticas adicionais recomendadas, para que você implemente quando for necessário.

Em primeiro lugar, invista nos serviços de testes de penetração o máximo possível para melhorar a descoberta de pontos fracos nas redes de seu ambiente. Essa é a primeira etapa do modelo de ciclo de vida e, se não for bem-sucedida, limitará severamente o sucesso de seus esforços no processo da gestão de vulnerabilidades. Técnicas de penetração são usadas para avaliar a segurança de uma rede de maneira controlada, mas não preocupe-se nesse momento se você não tiver conhecimento de todas essas técnicas, uma vez que elas serão apresentadas ao longo do curso.

Depois, uma das melhores maneiras de priorizar e avaliar os ativos dos seus ambientes é inventariar seus sistemas. Isso pode ajudar a identificar tecnologias implantadas que talvez estejam colocando seus sistemas em risco. Uma das coisas que você pode fazer para contribuir nessa etapa é classificar seus ativos de rede por plataforma. Você também deve identificar quais ferramentas defensivas já estão em vigor.

Empregar um serviço de gestão de vulnerabilidades seria discutível sem oferecer também serviço de *patch* adequado. Afinal, o *patch* geralmente é a única maneira de corrigir as ameaças às vulnerabilidades dos ativos, e uma forma de fazer a implementação é considerar o uso de uma solução automatizada de gerenciamento de *patches*, que poderá ajudar você a ficar em dia com as atualizações contínuas.

Sem um programa de gestão de vulnerabilidades, a segurança dos sistemas e da rede ficará suscetível a possíveis ameaças. Embora a introdução de um novo processo de gestão de vulnerabilidades na organização talvez seja desafiadora, é mais fácil seguir de perto o modelo do ciclo de vida, pois ele o ajudará na implementação das **diretrizes de serviço eficaz**.

Vamos finalizar este capítulo apresentando a diferença entre avaliação de vulnerabilidade e teste de penetração.

14 AVALIAÇÃO DE VULNERABILIDADE E TESTE DE PENETRAÇÃO

Muitos profissionais de segurança da informação estão familiarizados com os termos “avaliação de vulnerabilidade” e “teste de penetração” (*pentest*, de forma abreviada). Infelizmente, em muitos casos, esses dois termos são usados incorretamente e, como comentado anteriormente, vamos esclarecer as diferenças entre avaliação de vulnerabilidade e teste de penetração. Pretendemos demonstrar que ambos são componentes integrais de um programa completo de gestão de vulnerabilidades e indicar quando e onde cada um é mais apropriado.

Vamos relembrar o conceito: uma avaliação de vulnerabilidade é o processo de localizar e mensurar a gravidade das vulnerabilidades em um sistema. As avaliações de vulnerabilidade produzem relatórios das vulnerabilidades dos sistemas, geralmente priorizadas pela gravidade e/ou criticidade dos negócios.

As avaliações de vulnerabilidade geralmente envolvem o uso de ferramentas de teste automatizadas, como escâneres de segurança na web e na rede, cujos resultados são normalmente avaliados e encaminhados às equipes de desenvolvimento e operações. Em outras palavras, as avaliações de vulnerabilidade envolvem uma avaliação profunda de uma postura de segurança projetada para descobrir pontos fracos e recomendar a correção, ou a mitigação apropriada para remover ou, mesmo, a redução dos riscos.

Por outro lado, o teste de penetração é tipicamente um exercício orientado a objetivos. Um *pentest* tem menos a ver com a descoberta de vulnerabilidades e é mais focado em simular um ataque da vida real, em testar defesas e em traçar caminhos que um invasor real poderia seguir para atingir uma meta do mundo real. Em outras palavras, um teste de penetração trata-se mais sobre como um invasor é capaz de violar defesas e menos sobre vulnerabilidades específicas.

O teste de penetração, como a avaliação de vulnerabilidade, normalmente também envolve o uso de escâneres de vulnerabilidade automatizados e outras ferramentas manuais de teste para encontrar vulnerabilidades em aplicativos da web e infraestrutura de rede. Até esse ponto, a diferença fundamental entre a avaliação da vulnerabilidade e o teste de penetração é que o primeiro é orientado por relatórios e o último, orientado a objetivos.

Portanto, considerando que a avaliação da vulnerabilidade e o teste de penetração geralmente utilizam muitas das mesmas ferramentas e técnicas, por qual metodologia você deve optar, quando e por quê?

Como o teste de penetração verifica as defesas de segurança num caminho em direção a uma meta, geralmente é mais útil quando o nível de maturidade de segurança do alvo é alto, ou seja, quando se acredita que as defesas de segurança do alvo são fortes. O teste de penetração é uma metodologia eficaz para testar afirmações sobre as defesas dos sistemas com objetivos específicos em mente. Isso significa que o teste de penetração é mais adequado em situações nas quais a profundidade que se deseja alcançar em um sistema é preferida.

A avaliação de vulnerabilidade, por outro lado, é especialmente adequada em situações nas quais há problemas de segurança conhecidos ou quando uma organização que não possui a segurança necessária gostaria de passar a tê-la.

Como alternativa, a avaliação de vulnerabilidade é uma metodologia ideal para organizações que possuem uma maturidade de segurança média a alta e gostariam de manter sua postura de segurança por meio de uma avaliação contínua da vulnerabilidade. A avaliação de vulnerabilidade é, portanto, uma abordagem focada em fornecer às organizações uma lista de vulnerabilidades (relatórios) que precisam ser corrigidas, sem avaliar metas ou cenários específicos de ataques.



REFERÊNCIAS

ABNT. NBR ISO/IEC 27005:2008 – Tecnologia da Informação – Técnicas de Segurança – Gestão de Riscos de Segurança da Informação. ABNT, 2008.

CIS. Continuous Vulnerability Managament.[s.d.]. Disponível em: <<https://www.cisecurity.org/controls/continuous-vulnerability-management/>>. Acesso em: 8 abr. 2021.

KANDEK, W. **Vulnerability Management for Dummies**. 2015. Disponível em: <<https://blog.qualys.com/laws-of-vulnerabilities/2015/03/03/top-10-vulnerabilities-february-2015>>. Acesso em: 8 abr. 2021.

MUSCAT, I. **The difference between Vulnerability Assessment and Penetration Testing**. 2017. Disponível em: <<https://www.acunetix.com/blog/articles/difference-vulnerability-assessment-penetration-testing/>>. Acesso em: 8 abr. 2021.

NVD. National Vulnerability Database. **Vulnerability Metrics**. Disponível em: <<https://nvd.nist.gov/vuln-metrics/cvss>>. Acesso em: 8 abr. 2021

SCARFONE, K. *et. al.* **Technical Guide to Information Security Testing and Assessment**. [s.l.]: NIST, 2008. Disponível em: <<http://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-115.pdf>>. Acesso em: 8 abr. 2021

SMITH, T. **Over 80% of Breaches Still Result of Poor Patch Management**. 2017. Disponível em: <<https://dzone.com/articles/80-of-breaches-still-result-of-poor-patch-manageme>>. Acesso em: 8 abr. 2021.

SOULDERS, J. **Flexibility in Vulnerability Management: Why it's Essential**. Cyber Defense Magazine. 2019. Disponível em: <https://cyberdefensemagazine.tradepub.com/free/w_cyba58/>. Acesso em: 8 abr. 2021.